



**FREE
DOWNLOAD**

BUG BOUNTY CHEATSHEET

[MUQSITBAIG.COM](https://muqsitbaig.com)

[!\[\]\(d66ff64371a51729ac8c1cdaa685ba6f_img.jpg\) YOUTUBE.COM/@MUQSITBAIG](https://www.youtube.com/@muqsitbaig)

Disclaimer

This guide is a compilation of information and resources gathered from various sources. While I have curated and presented them here, the original credit for each piece of information belongs to its respective author(s). I encourage you to explore the original sources for further details and deeper understanding.

Feel free to share this document and contribute to its growth by adding more resources, tools, or best practices related to bug bounty hunting. Remember to appropriately credit any additional information you include.

This bug bounty cheat sheet is provided for educational purposes only. While every effort has been made to ensure the accuracy of the information provided, the author and publisher assume no responsibility for errors or omissions, or for any damages resulting from the use of the information contained herein. Readers are advised to use their discretion and conduct thorough research before engaging in bug bounty activities. Additionally, it is important to abide by the terms and conditions of bug bounty programs and to act responsibly and ethically at all times. By downloading this cheatsheet, you agree to use the information contained within it responsibly and at your own risk.

M Q S T

Subscribe to my YouTube channel: youtube.com/@muqsitbaig

Newsletter to stay up to date with the field of Cyber Security and to get such FREEBIES: newsletter.muqsitbaig.com

Follow on X/Twitter: [mqst - Twitter](https://twitter.com/mqst)

Bug Bounty Eagles Eye View

Pre-Engagement

Choose a target: Select programs based on your skills, interests, and reward potential.

Understand scope: Review program rules, scope documents, and exclusion zones. Gather basic information like domain name, technology stack, and known functionalities. Make sure not to scan or run any tools which have are active in nature(active recon or scanning or fuzzing tools or bruteforcing tools)

Gather information: Conduct passive recon: social media, news, github repos, product documentation, DNS records, Wayback Machine, etc.

Engagement

Phase 1: Reconnaissance

- **Passive Recon:** Use passive sources like:
 - Search engines: Search for news, technical write-ups, and social media mentions.
 - Wayback Machine: Explore past versions of the website for potential vulnerabilities or leaks.
 - DNS records: Query for subdomains, MX records, and other details.
 - Github repos
 - ASN Enumeration
- **Active recon:** Use tools like Subfinder, Nuclei, SpiderFoot to discover subdomains, technologies, and attack vectors.
- **Application mapping:** Manually and with tools like Burp Suite, map the application structure and functionalities.
- **Technology identification:** Use Wappalyzer or similar tools to identify frameworks, libraries, and versions.
- **Prioritize vulnerabilities:** Focus on high-impact areas like OWASP Top 10 and those based on the identified technology.

Phase 2: Scanning & Fuzzing

- **Automated scans:** Use scanners like Burp Suite, Zap, etc to uncover basic vulnerabilities.
- **Manual testing:** Complement scans with manual testing for unique vulnerabilities and deeper understanding - Business logic testing.
- **Fuzzing:** Utilize tools like Wfuzz or GoFuzz for custom input manipulation and vulnerability discovery (ONLY IF IT IS ALLOWED IN THE PROGRAM'S POLICY)

Phase 3: Exploitation & Verification

- Exploit development: If needed, develop or leverage existing exploits to confirm vulnerabilities.
- Proof of concept: Create clear and reproducible proof of concept for each vulnerability.
- Impact assessment: Estimate the potential impact of each vulnerability on the target.

Phase 4: Reporting & Follow-up

- Draft report: Write a concise, detailed report describing the vulnerabilities, impact, and recommendations.
- Submit report: Follow program guidelines and communication channels for report submission.
- Respond to queries: Be prepared to answer questions and provide additional information from program managers.
- Track progress: Monitor bug bounty platform for updates, resolutions, and bounty awards.

Post-Engagement

- Document findings: Maintain records of your work for future reference and learning.
- Share knowledge: Contribute to the community by writing blog posts or participating in forums.
- Learn from feedback: Analyze program feedback to improve your skills and methodology.

Bonus Tips

- Start small: Focus on beginner-friendly programs and tools before tackling complex targets.
- Join communities: Engage with other bug bounty hunters for learning, collaboration, and motivation.
- Stay ethical: Respect program rules, avoid unauthorized testing, and act responsibly.
- Focus on learning: Continuous learning and skill development are crucial for success.
- Don't give up: Persistence and patience are key to finding impactful vulnerabilities.

Bug Bounty Recon Cheat Sheet

Bug Bounty Platforms

- HackerOne
- Bugcrowd
- Synack
- Cobalt
- YesWeHack
- Intigriti
- Open Bug Bounty
- Zerocopter
- Detectify
- Yogosha
- BountyFactory
- HackenProof
- BountyGraph
- FireBounty
- Immunefi
- Red Siege
- Bugwolf

M Q S T

IP Enumeration

ASNLookup: This tool leverages ASN to look up IP addresses (IPv4 & IPv6) owned by a specific organization for reconnaissance purposes.

Fav-Up: Lookups for real IP starting from the favicon icon and using Shodan.

Usage: `python3 favUp.py --favicon-file favicon.ico -sc`

One Liner for Listing IP Addresses in CIDR Block: List all IP addresses in a given CIDR block.

Usage: `nmap -sL -n 10.10.64.0/27 | awk '/Nmap scan report/{print $NF}'`

-sL: List Scan - simply list targets to scan

-n: Never do DNS resolution

CDN IP Ranges: Lists of IP ranges used by CDNs (Cloudflare, Akamai, Incapsula, Fastly, etc), updated every 30 minutes.

Netlas: Internet intelligence apps providing accurate technical information on IP addresses, domain names, websites, web applications, IoT devices, and other online assets.

CloudPeler: This tool helps to see the real IP behind CloudFlare protected websites.

Rapid7 DNSGrep: A utility for quickly searching presorted DNS names. Built around the Rapid7 rdns & fdns dataset.

Certificate Search: Certificate Search powered by crt.sh.

Censys: Censys is a reputable source of Internet scan data, allowing you to see everything.

Shodan: Shodan is the world's first search engine for Internet-connected devices.

FullHunt: FullHunt helps identify vulnerable internet-facing assets.

Fofax: Fofax is a fofa query tool positioned as a command-line tool for simplicity and speed.

Usage: `fofax -q 'app="APACHE-Solr"'`

PublicWWW: Find any alphanumeric snippet, signature, or keyword in web pages HTML, JS, and CSS code.

FOFA: FOFA is the world's IT equipment search engine with more complete data coverage.

ZoomEye: ZoomEye is China's first and world-renowned cyberspace search engine.

SecurityTrails: Total Internet Inventory with the most comprehensive data.

Reverse Whois Tool: This free tool will allow you to find domain names owned by an individual person or company.

WHOXY: WHOXY's WHOIS API returns consistent and well-structured WHOIS data in XML & JSON format.

Web Cache Checker: Lists web files on a website that are cached and those that are not.

Subdomain Enumeration

Certificate Search: Certificate Search powered by crt.sh.

Amass: The OWASP Amass Project performs network mapping of attack surfaces and external asset discovery.

Usage: `amass enum -passive -dir /tmp/amass_output/ -d example.com -o dir/example.com`

Gotator: Gotator is a tool to generate DNS wordlists through permutations.

Usage: `gotator -sub domains.txt -perm permutations.txt -depth 2 -numbers 5 > output.txt`

Altdns: Altdns is a DNS recon tool that allows for the discovery of subdomains that conform to patterns.

Usage: `altdns -i subdomains.txt -o data_output -w words.txt -r -s results_output.txt`

Subfinder: subfinder is a subdomain discovery tool that discovers valid subdomains for websites using passive online sources.

Usage: `subfinder -r <IP address> -t 10 -v -d example.com -o dir/example.com`

SubDomainizer: SubDomainizer is a tool designed to find hidden subdomains and secrets present on webpages.

Usage: `python3 SubDomainizer.py -u example.com -o dir/example.com`

DNS Bufferover Run: A utility for quickly searching presorted DNS names.

Censys: Censys is a reputable source of Internet scan data, allowing you to see everything.

Shodan: Shodan is the world's first search engine for Internet-connected devices.

Fofax: Fofax is a fofa query tool positioned as a command-line tool for simplicity and speed.

Usage: `fofax -q 'app="APACHE-Solr"'`

PublicWWW: Find any alphanumeric snippet, signature, or keyword in web pages HTML, JS, and CSS code.

Reverse Whois Tool: This free tool will allow you to find domain names owned by an individual person or company.

ZoomEye: ZoomEye is China's first and world-renowned cyberspace search engine.

SecurityTrails: Total Internet Inventory with the most comprehensive data.

Web Cache Checker: Lists web files on a website that are cached and those that are not.

WHOXY: WHOXY's WHOIS API returns consistent and well-structured WHOIS data in XML & JSON format.

M Q S T

Wayback Machine

[gau](#): gau (getallurls) fetches known URLs from AlienVault's Open Threat Exchange, the Wayback Machine, and Common Crawl for any given domain.

Usage: `cat domains.txt | gau --threads 5`

[Waybackurls](#): Accepts line-delimited domains on stdin, fetches known URLs from the Wayback Machine for *.domain, and outputs them on stdout.

Usage: `cat subdomains.txt | waybackurls > waybackurls.txt`

[Hacks](#): Hacky one-off scripts, tests, etc.

Usage: `cat waybackurls.txt | go run
/root/Tools/hacks/anti-burl/main.go | tee waybackurls_valid.txt`



Cache

[Cache Checker](#): This tool lists which web files on a website are cached and which are not. It also checks by which method these files are cached and what the expiry time of the cached files is.

[Cache Poisoning at Scale](#): Learn how cache poisoning attacks can be achieved at scale.



Crawling

[Hakrawler](#): Fast golang web crawler for gathering URLs and JavaScript file locations.

Usage: `echo https://example.com | hakrawler`

[Katana](#): A next-generation crawling and spidering framework.

Usage: `katana -u https://example.com`

[Gospider](#): Fast web spider written in Go.

Usage: `gospider -s "https://example.com/" -o output -c 20 -d 10`

[Common Crawl](#): Common Crawl provides open access to web crawl data.

[Geo Browse](#): Geo Browse captures screenshots of your website from different countries.

[xnLinkFinder](#): Discover endpoints (and potential parameters) for a given target.

M Q S T

Wordlist

[SecLists](#): SecLists is a collection of multiple types of lists used during security assessments, including usernames, passwords, URLs, sensitive data patterns, fuzzing payloads, web shells, and more.

[PayloadsAllTheThings](#): PayloadsAllTheThings is a list of useful payloads and bypasses for Web Application Security.

[WordlistGen](#): WordlistGen is a tool to pass a list of URLs and get back a list of relevant words for your wordlists.

Usage: `cat hostlist.txt | wordlistgen`

[Wordlists](#): Wordlists.assetnote.io provides up-to-date and effective wordlists against the most popular technologies on the internet.

[Google Fuzzing](#): This project aims to host tutorials, examples, discussions, research proposals, and other resources related to fuzzing.

[FuzzDB](#): FuzzDB is a collection of lists that increase the likelihood of finding application security vulnerabilities through dynamic application security testing.

M Q S T